

Xavfsizlik auditi hisoboti

Tekshirilgan IP: <Target_IP>

Asosiy topilma: Internetga ochiq recursive DNS resolver va o'lchangan DNS response amplification

Holat: Tasdiqlangan konfiguratsiya xavfi

1. Qisqa xulosa

<Target_IP> manzilida DNS xizmati Internet orqali ochiq va server tashqi domenlar uchun DNS recursion xizmatini bajarmoqda.

Tekshiruvda:

- UDP/53 ochiq ekanligi tasdiqlandi;
- server **google.com**, **microsoft.com**, **cloudflare.com**, **wikipedia.org** kabi tashqi domenlarni resolve qildi;
- DNS javoblarida **RA (Recursion Available)** flag kuzatildi;
- real **tcpdump** packet capture orqali request/response hajmlari o'lchandi;
- turli querylarda response requestdan **2.46x-5.68x** katta bo'ldi;
- eng katta o'lchangan natija **AAAA example.com: 57 B → 324 B = 5.68x**;
- **DNSKEY cloudflare.com: 83 B → 431 B = 5.19x**.

Shu sababli server **DNS reflection/amplification DDoS hujumlarida reflector sifatida suiiste'mol qilinishi mumkin bo'lgan konfiguratsiyaga ega**.

Muhim: uchinchi tomon tizimiga DDoS yoki source-IP spoofing hujumi yuborilmadi. Xulosa diagnostik testlar, real packet capture va o'lchangan qiymatlarga asoslangan.

2. Finding: Internetga ochiq recursive DNS resolver

Muammo

DNS resolver domen nomlarini IP manzilga aylantiradi. Tekshiruvda server faqat ichki domenlar emas, Internetdagi umumiy domenlar uchun ham recursion bajarayotgani aniqlandi.

Misol:

```
dig @<Target_IP> google.com A
dig @<Target_IP> microsoft.com A
dig @<Target_IP> cloudflare.com A
```

Javoblarda:

flags: qr rd ra

ko'rindi.

RA — Recursion Available, ya'ni server recursionni qo'llab-quvvatlashini bildiradi.

3. UDP/53 ochiqligi

Nmap:

```
53/udp open domain udp-response
```

TCP/53 ham kuzatildi:

```
53/tcp open domain Mikrotik dnssd
```

Asosiy finding UDP/53 orqali Internetdan foydalanish mumkin bo'lgan resolverga tegishli.

4. Tashqi domenlarni resolve qilish

Quyidagi so'rovlar muvaffaqiyatli bajarildi:

```
dig @<Target_IP> google.com A
dig @<Target_IP> microsoft.com A
dig @<Target_IP> cloudflare.com A
dig @<Target_IP> wikipedia.org A
dig @<Target_IP> example.com A
```

Masalan:

```
SERVER: <Target_IP>#53
status: NOERROR
flags: qr rd ra
```

Bu server Internet domenlari uchun recursive DNS xizmatini ko'rsatayotganini amaliy tasdiqlaydi.

5. NXDOMAIN testi

Mavjud bo'lmagan domenlar ham tekshirildi:

```
dig @<Target_IP> nonexistent-random-domain-938472.example A
dig @<Target_IP> x7k29m4q9p.google.com A
```

Natijalarda:

```
status: NXDOMAIN
```

olindi.

Bu resolverning turli DNS querylarni normal qayta ishlayotganini ko'rsatadi.

6. +norecurse testi

Quyidagi test bajarildi:

```
dig @<Target_IP> cloudflare.com A +norecurse
```

Server javob qaytardi va **RA** flag kuzatildi.

Eslatma: **+norecurse** natijasi yakka holda "open recursion"ning yagona isboti sifatida ishlatilmaydi. Asosiy dalil — tashqi domenlarni server orqali resolve qilish va **RA** flagidir.

7. DNS Response Amplification o'lchovi

Real tarmoq packetlari quyidagi buyruq bilan kuzatildi:

```
sudo tcpdump -ni any -s0 -vv 'host <Target_IP> and udp port 53'
```

Hisoblash:

Amplification Factor =
Response IP packet size / Request IP packet size

O'lchangan natijalar

DNS query	Request	Response	Amplification
A example.com	57 B	300 B	5.26x
AAAA example.com	57 B	324 B	5.68x
MX example.com	57 B	283 B	4.96x
NS example.com	57 B	140 B	2.46x
TXT example.com	57 B	181 B	3.18x
DNSKEY cloudflare.com	83 B	431 B	5.19x
DS cloudflare.com	83 B	319 B	3.84x
A cloudflare.com	83 B	303 B	3.65x

Eng katta natija

AAAA example.com
Request: 57 bytes
Response: 324 bytes

$$324 / 57 = 5.68x$$

Bu real packet capture orqali o'lchangan natijadir.

8. DNSSEC testi

```
dig @<Target_IP> cloudflare.com DNSKEY +dnssec
```

Packet capture:

Request IP length: 83
Response IP length: 431

Hisob:

$$431 / 83 = 5.19x$$

Bu DNSSEC bilan bog'liq querylarda ham response requestdan sezilarli katta bo'lishi mumkinligini ko'rsatadi.

9. Biznes va texnik xavf

Agar Internetdagi hujumchi ushbu resolverdan foydalanib DNS reflection/amplification hujumini tashkil qilsa, server uchinchi tomon nishoniga yuboriladigan trafficning reflector qismi bo'lishi mumkin. Soddalashtirilgan model:



Potensial oqibatlar:

1. Tashkilot IP manzili abuse faoliyatida ko'rinishi.
2. ISP yoki boshqa operatorlardan abuse/shikoyatlar kelishi.
3. IP reputation yomonlashishi yoki tarmoq cheklovleri.
4. DNS server va Internet kanalida keraksiz trafik va resource sarfi.
5. Bir xil tarmoq/infratuzilmadagi boshqa biznes xizmatlariga bilvosita ta'sir.

Bu auditda real DDoS, source-IP spoofing yoki uchinchi tomon nishoniga trafik yuborish amalga oshirilmagan. Shuning uchun "real DDoS muvaffaqiyatli bajarildi" degan da'vo qilinmaydi. Tasdiqlangan holat — Internetga ochiq recursion va amaliy o'lchangan response amplification.

10. Tavsiya

Agar server Internet uchun authoritative DNS server bo'lmasa:

- Internetdan recursive DNS accessni yopish;
- recursionni faqat ichki LAN/VPN/ruxsat etilgan IP diapazonlariga cheklash;
- firewall orqali UDP/53 va kerak bo'lsa TCP/53 ni trusted source'larga cheklash;
- authoritative DNS va recursive resolver funksiyalarini ajratish.

Agar Internetdan DNS xizmatini ochiq qoldirish biznes jihatdan zarur bo'lsa, recursion uchun qat'iy ACL va firewall siyosati joriy qilinishi kerak.

11. Tekshirilgan boshqa servislar

21/tcp — FTP

21/tcp open tcpwrapped

Tekshiruv davomida tasdiqlangan yuqori darajadagi zaiflik aniqlanmadi. **Natija:** E'tiborga loyiq tasdiqlangan topilma aniqlanmadi.

80/tcp — HTTP

80/tcp open http
Server: openresty
Location: https://sam.pro

HTTP so'rovlari **sam.pro** ga redirect qilinadi. **Natija:** Ushbu tekshiruv doirasida 80/tcp bo'yicha tasdiqlangan yuqori darajadagi zaiflik aniqlanmadi.

443/tcp — HTTPS

443/tcp open ssl/https
Server: openresty

IP orqali to'g'ridan-to'g'ri HTTPS so'rovlari tekshirildi. **Natija:** Audit doirasida 443/tcp bo'yicha tasdiqlangan yuqori darajadagi zaiflik aniqlanmadi.

2000/tcp — MikroTik Bandwidth Test

2000/tcp open
MikroTik bandwidth-test server

UDP/2000:

2000/udp closed

TCP/2000 Internetga ochiqligi alohida exposure hisoblanadi, ammo ushbu auditda u orqali exploitable vulnerability isbotlanmadi.

Natija: Exposure mavjud; tasdiqlangan exploitable vulnerability aniqlanmadi.

2022/tcp — SSH

2022/tcp open ssh
OpenSSH 9.6p1 Ubuntu 3ubuntu13.18

SSH ochiqligi o'z-o'zidan zaiflik emas.

Audit davomida tasdiqlangan exploitable vulnerability aniqlanmadi.

Natija: Tasdiqlangan yuqori darajadagi zaiflik aniqlanmadi.

8080/tcp — Huly

8080/tcp open http
nginx 1.21.3
X-Powered-By: Express
HTTP title: Huly

Interfeysda:

Huly 0.7.423

versiyasi ko'rindi.

Yangi account yaratish, authentication va JWT tokenlari tekshirildi. JWT:

alg: HS256

ekanligi aniqlandi.

Token manipulyatsiyasi va authentication bypass urinishlari orqali tasdiqlangan account takeover yoki authorization bypass aniqlanmadi. URL orqali ayrim resurslarga murojaat qilinganda authentication sahifasiga redirect kuzatildi.

Natija: Hozirgi dalillar asosida Huly bo'yicha tasdiqlangan exploitable vulnerability ko'rsatilmagan.

12. IP manzil va infratuzilma

WHOIS:

<Diapazon_IP>.0 - <Diapazon_IP>.255
netname: UZTELECOM
country: UZ
origin: AS8193

IP diapazoni Uzbektelecom infratuzilmasiga tegishli.

Reverse DNS:

NXDOMAIN

Geolocation Tashkent, Uzbekistan ko'rsatgan, biroq geolocation serverning haqiqiy biznes egasini isbotlamaydi.

SOC infratuzilmasiga tegishlilik gipotezasi

80/tcp ning **sam.pro** ga redirect qilishi va IP'dagi boshqa servislar sababli IP manzil SOC/monitoring infratuzilmasiga tegishli bo'lishi mumkin degan gipoteza mavjud.

Biroq:

IP manzil aynan SOC tashkilotining o'ziga tegishli ekanligi hozirgi dalillar bilan 100% tasdiqlanmagan.

WHOIS IP blok operatorini ko'rsatadi, konkret serverning oxirgi biznes foydalanuvchisini emas. Shuning uchun bu **tasdiqlanmagan gipoteza**, finding emas.

13. Operatsion tizim va texnologiyalar

Nmap natijalariga ko'ra:

OS family: Linux

SSH banner:

OpenSSH_9.6p1 Ubuntu 3ubuntu13.18

Demak ochiq servislar orasida Linux/Ubuntu komponentlari mavjudligi yuqori ishonch bilan aytiladi. Fingerprint qilingan texnologiyalar:

OpenResty
nginx 1.21.3
Express
Huly
MikroTik DNS
MikroTik bandwidth-test
OpenSSH 9.6p1 Ubuntu

Bu butun qurilmaning yagona OS'i degani emas; servis bannerlari orqali aniqlangan komponentlardir.

14. Dalillar ishonchliligi

Da'vo	Dalil	Ishonchlilik
UDP/53 ochiq	Nmap	Yuqori
DNS resolver ishlayapti	dig	Yuqori
Recursive DNS mavjud	RA + tashqi domen resolution	Yuqori
Internet domenlari resolve qilinadi	dig	Yuqori
Response requestdan katta	tcpdump	Yuqori
2.46x-5.68x amplification	real packet sizes	Yuqori
DNSSEC response kattaligi	DNSKEY packet capture	Yuqori
Reflection/amplification xavfi	yuqoridagi faktlar + standart DNS modeli	Yuqori
Real DDoS amalga oshirilgan	Test qilinmagan	Tasdiqlanmagan
IP SOCga tegishli	redirect va servislar asosidagi gipoteza	Tasdiqlanmagan
Linux/Ubuntu komponentlari	Nmap/banner	Yuqori

15. Yakuniy xulosa

Eng aniq va texnik jihatdan isbotlangan finding:

<Target_IP> Internetdan foydalanish mumkin bo'lgan recursive DNS resolver sifatida ishlamoqda va turli DNS querylar uchun response hajmi request hajmidan sezilarli katta ekanligi real packet capture orqali tasdiqlandi.

O'lchangan amplification:

Minimum: 2.46x
Maximum: 5.68x

Bu konfiguratsiya DNS reflection/amplification DDoS hujumlarida serverning reflector sifatida suiiste'mol qilinish xavfini yaratadi.

Hujumchi DNS so'rovining manzilini qalbakilashtirib, ushbu serverni boshqa tashkilot yoki serverga katta hajmdagi DNS javoblarini yuboruvchi bo'ladi.

Tavsiya: Internetdan recursive DNS accessni yopish yoki uni faqat ishonchli ichki/VPN tarmoqlar bilan cheklash.

Ilova A — asosiy testlar

```
sudo nmap -sU -p53 --reason <Target_IP>
```

```
dig @<Target_IP> google.com A
dig @<Target_IP> microsoft.com A
dig @<Target_IP> cloudflare.com A
```

```
dig @<Target_IP> nonexistent-random-domain-938472.example A
```

```
dig @<Target_IP> cloudflare.com A +norecurse
```

```
sudo tcpdump -ni any -s0 -vv 'host <Target_IP> and udp port 53'
```

```
nmap -sV -p21,53,80,443,2000,2022,8080 --script=banner,http-title,http-headers,ssl-cert <Target_IP>
```

Ilova B — packet capture misollari

```
172.20.10.5 → <Target_IP>
length 57
```

```
<Target_IP> → 172.20.10.5
length 300
```

A example.com:

$300 / 57 = 5.26\times$

AAAA example.com:

$324 / 57 = 5.68\times$

DNSKEY cloudflare.com:

$431 / 83 = 5.19\times$

Ushbu qiymatlar real packet capture natijalaridan hisoblangan.